

Análisis de Incidente de Seguridad - Ataque DDoS (ICMP Flood)

Empresa Multimedia - Servicios de Diseño Web, Gráfico y Marketing

Fecha del incidente: [Inserta fecha aproximada]

Analista: Luis Antonio

Marco utilizado: NIST Cybersecurity Framework (CSF)

Resumen (Summary)

Esta mañana, la red interna de la empresa quedó inaccesible durante aproximadamente dos horas debido a un ataque de denegación de servicio distribuido (DDoS) volumétrico. Un actor malicioso envió una avalancha masiva de paquetes ICMP (pings) entrantes que saturaron el firewall mal configurado, impidiendo el tráfico legítimo y afectando todos los servicios internos (acceso a servidores de diseño, bases de datos de clientes, herramientas de colaboración y marketing en redes sociales).

El equipo de gestión de incidentes respondió rápidamente bloqueando los paquetes ICMP entrantes, desactivando servicios no críticos y restaurando los críticos. La investigación posterior confirmó que la causa raíz fue la falta de reglas de limitación de tasa y verificación de origen en el firewall.

Se implementaron medidas inmediatas y se propone un plan de mejoras usando el NIST CSF para fortalecer la resiliencia y evitar recurrencias.

Identify (Identificar)

- Tipo de ataque: DDoS volumétrico en capa 3/4 (inundación ICMP / ping flood).
- Sistemas y activos afectados: Firewall perimetral, red interna completa, switches/routers, estaciones de trabajo de diseñadores y community managers, servidores web y bases de datos de clientes.
- Brechas identificadas: Configuración incompleta del firewall (sin rate limiting ni anti-spoofing para ICMP), falta de monitoreo proactivo de tráfico anómalo.
- Análisis inicial: Revisión de logs del firewall y tráfico de red (NetFlow o similar) confirmando gran volumen de paquetes ICMP con posibles direcciones IP spoofed.

Protect (Proteger)

Medidas aplicadas:

- Regla de firewall para limitar paquetes ICMP (rate limiting).

- Verificación de dirección IP de origen (anti-spoofing).
- Configuración adicional en firewall/IPS para filtrar tráfico sospechoso.

Mejoras propuestas:

- Capacitación por roles sobre conciencia de seguridad.
- Hardening del firewall (deny por defecto y auditorías).
- Segmentación de red con VLANs.
- Protección de endpoints con antivirus/EDR.
- Acceso remoto seguro vía VPN y evaluación de mitigación DDoS en la nube.

Detect (Detectar)

Medidas implementadas:

- Software de monitoreo de red.
- Sistema IDS/IPS para identificar tráfico ICMP sospechoso.

Mejoras propuestas:

- Alertas automáticas por umbrales de tráfico ICMP.
- Centralización de logs mediante SIEM.
- Monitoreo continuo del enlace de Internet.
- Escaneos de configuración y pruebas de estrés periódicas.

Respond (Responder)

Acciones tomadas:

- Bloqueo inmediato de ICMP entrante.
- Desactivación de servicios no críticos.

- Restauración de servicios esenciales.

Plan futuro:

- Playbook específico para incidentes DDoS.
- Comunicación interna rápida (<15 minutos).
- Reportes post-incidente para empleados.
- Reunión de lecciones aprendidas en 48 horas.

Recover (Recuperar)

Acciones tomadas:

- Restauración progresiva de servicios críticos.

Mejoras propuestas:

- Pruebas regulares de continuidad.
- Monitoreo intensivo posterior al incidente.
- Trabajo remoto vía VPN si ocurre otra interrupción.
- Evaluación de nube híbrida con alta disponibilidad.

Reflexiones / Notas

Este incidente resaltó la importancia de la defensa en capas y la correcta configuración del perímetro. La capacitación por roles y los reportes claros ayudarán a crear una cultura de seguridad dentro de la empresa. Las mejoras propuestas son escalables para una pyme y están alineadas con el NIST CSF para reducir riesgos futuros.

Firma:

Luis Antonio

Analista de Ciberseguridad

Fecha: [Inserta fecha]